

Day21 信息打点-公众号服务&Github监控&供应链&网盘泄漏&证书图标邮箱资产

业务资产

- 查询平台
 - 爱企查
 - 小蓝本
- 业务类型
 - 1、WEB应用
 - 2、APP应用
 - 3、PC端应用
 - 4、小程序应用
 - 5、微信公众号
 - 6、其他产品等

架构

- 分类
 - 1、程序语言
 - 2、框架源码
 - 3、搭建平台
 - 4、数据库类
 - 5、操作系统

技术

- 指纹识别
 - 平台
 - 指纹识别 Wappalyzer <https://github.com/AliaSI0/wappalyzer>
 - 指纹识别 TideFinger潮汐 <http://finger.tideseccn.net/>
 - 指纹识别 云悉指纹 <https://www.yunsee.cn/>
 - 内网: cmsseek cmsmap

域名

- 单域名
 - 1、备案信息
 - 2、企业产权
 - 3、注册域名
 - 4、反查解析
- 子域名
 - 1、DNS数据
 - 2、证书查询
 - 3、网络空间
 - 4、威胁情报
 - 5、枚举解析

- 平台
 - DNS数据 [dnsdumpster https://dnsdumpster.com/](https://dnsdumpster.com/)
 - 证书查询 [CertificateSearch https://crt.sh/](https://crt.sh/)
 - 网络空间 [FOFA https://fofa.info/](https://fofa.info/)
 - 网络空间 全球鹰 <http://hunter.qianxin.com/>
 - 网络空间 360 <https://quake.360.cn/quake/#/index>
 - 威胁情报 微步在线 情报社区 <https://x.threatbook.cn/>
 - 枚举解析 DNSGrep子域名查询 <https://www.dnsgrep.cn/subdomain>
 - 枚举解析 工具强大的子域名收集器 <https://github.com/shmilylty/OneForAll>

开源

- 利用指纹识别找到CMS
- 官方去下载

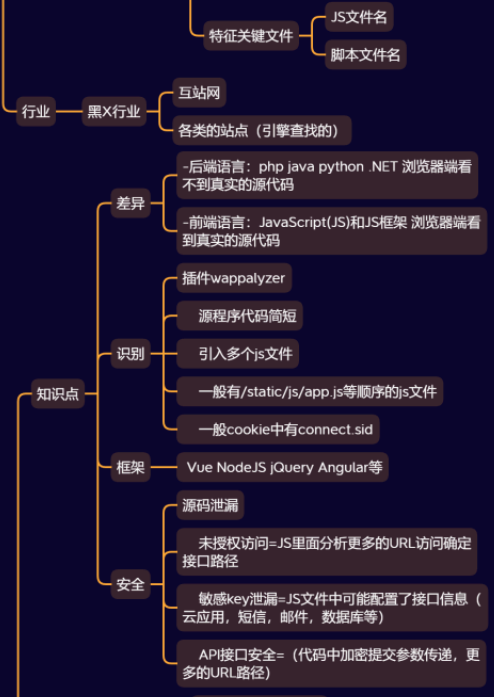
源码获取

闭源

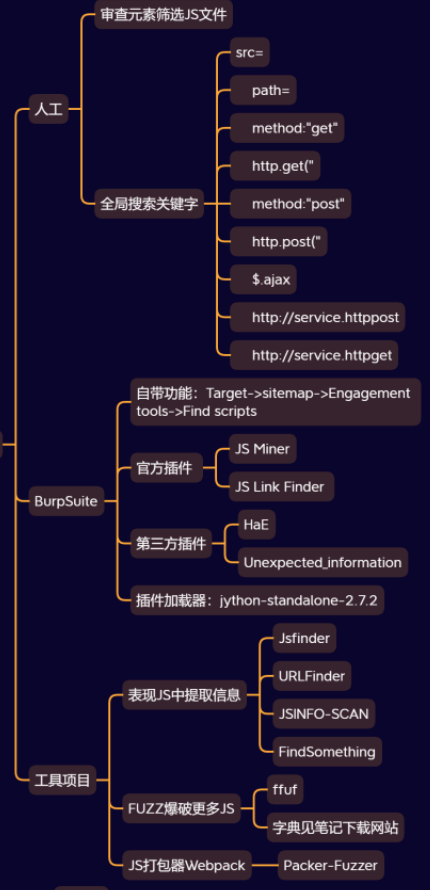
- 漏洞方案
 - git
 - svn
 - ds_store
 - 压缩备份
 - composer
- 平台
 - github
 - gitee
 - oschina
- 码云资源搜索
 - 信息搜索
 - QQ号
 - 邮箱地址
 - 作者名
 - 注释关键信息

① Web应用

JS前端架构



测试方法

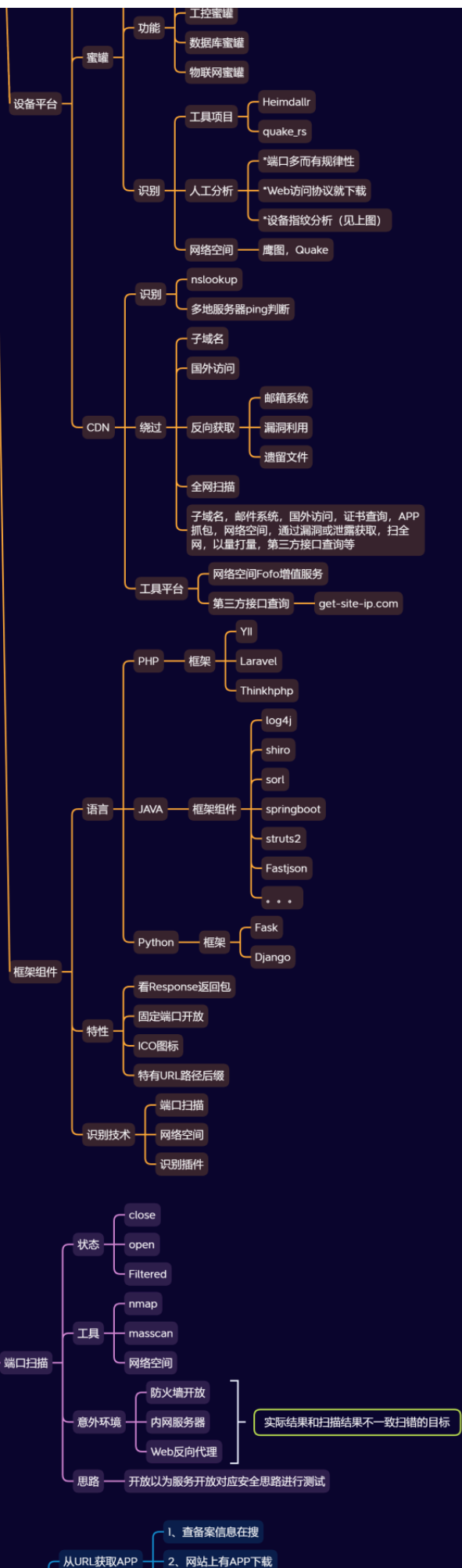


WAF



信息打点-小迪安全

③ 主机服务器





1.知识点

- 1、业务资产-应用类型分类
- 2、Web单域名获取-接口查询
- 3、Web子域名获取-解析枚举
- 4、Web架构资产-平台指纹识别

-
- 1、开源-CMS指纹识别源码获取方式
 - 2、闭源-习惯&配置&特性等获取方式
 - 3、闭源-托管资产平台资源搜索监控

-
- 1、JS前端架构-识别&分析
 - 2、JS前端架构-开发框架分析
 - 3、JS前端架构-打包器分析
 - 4、JS前端架构-提取&FUZZ

解决:

- 1、如何从表现中的JS提取价值信息
- 2、如何从地址中FUZZ提取未知的JS文件
- 3、如何从JS开放框架WebPack进行测试

-
- 1、端口扫描-应用&协议
 - 2、WAF识别-分类&识别
 - 3、蜜罐识别-分类&识别

解决:

- 1、Web服务器&应用服务器差异性
- 2、WAF防火墙&安全防护&识别技术
- 3、蜜罐平台&安全防护&识别技术

-
- 1、CDN 服务-解释差异识别
 - 2、CDN 绕过-配置差异导致
 - 3、CDN 绕过-主动连接获取
 - 4、CDN 绕过-全网扫描获取

解决:

1、CDN 服务对安全影响

2、CDN 服务绕过识别手法

- 1、CMS指纹识别-不出网程序识别
- 2、开发框架识别-PHP&Python&Java
- 3、开发组件识别-Java常见安全漏洞组件

解决:

- 1、CMS识别到后期漏洞利用和代码审计
 - 2、开发框架识别到后期漏洞利用和代码审计
 - 3、开发组件识别到后期漏洞利用和代码审计
-

- 1、Web&备案信息&单位名称中发现APP
- 2、APP资产静态提取&动态抓包&动态调试

解决:

- 1、如何获取到目标APP信息
 - 2、如何从APP信息中提取资产
-

- 1、Web&备案信息&单位名称中发现小程序
- 2、小程序资产静态提取&动态抓包&动态调试

解决:

- 1、如何获取到目标小程序信息
 - 2、如何从小程序中提取资产信息
-

- 0、工具项目-红蓝队&自动化部署
 - 1、工具项目-自动化侦查收集提取
 - 2、工具项目-综合&网络空间&信息
-

- 1、开发泄漏-Github监控
 - 2、文件泄漏-网盘全局搜索
 - 3、架构泄漏-目录扫码&爬虫
 - 4、其他泄漏-公众号服务资产
 - 4、收集进阶-证书&图标&邮箱
-

2.详细点



- 1 CMS
- 2 Discuz、WordPress、Ecshop、蝉知等



- 1 前端技术
- 2 HTML5、jquery、bootstrap、Vue等



- 1 开发语言
- 2 PHP、JAVA、Ruby、Python、C#、JS等



- 1 Web服务器
- 2 Apache、Nginx、IIS、lighttpd、Apache等



- 1 应用服务器:
- 2 Tomcat、Jboss、weblogic、websphere等



- 1 数据库类型:
- 2 Mysql、SqlServer、Oracle、Redis、MongoDB等



- 1 操作系统信息
- 2 Linux、windows等



- 1 应用服务信息:
- 2 FTP、SSH、RDP、SMB、SMTP、LDAP、Rsync等



- 1 CDN信息
- 2 帝联、Cloudflare、网宿、七牛云、阿里云等



- 1 WAF信息
- 2 创宇盾、宝塔、ModSecurity、玄武盾、OpenRASP等。

- 1 蜜罐信息:
- 2 HFish、TeaPot、T-Pot、Glastopf等

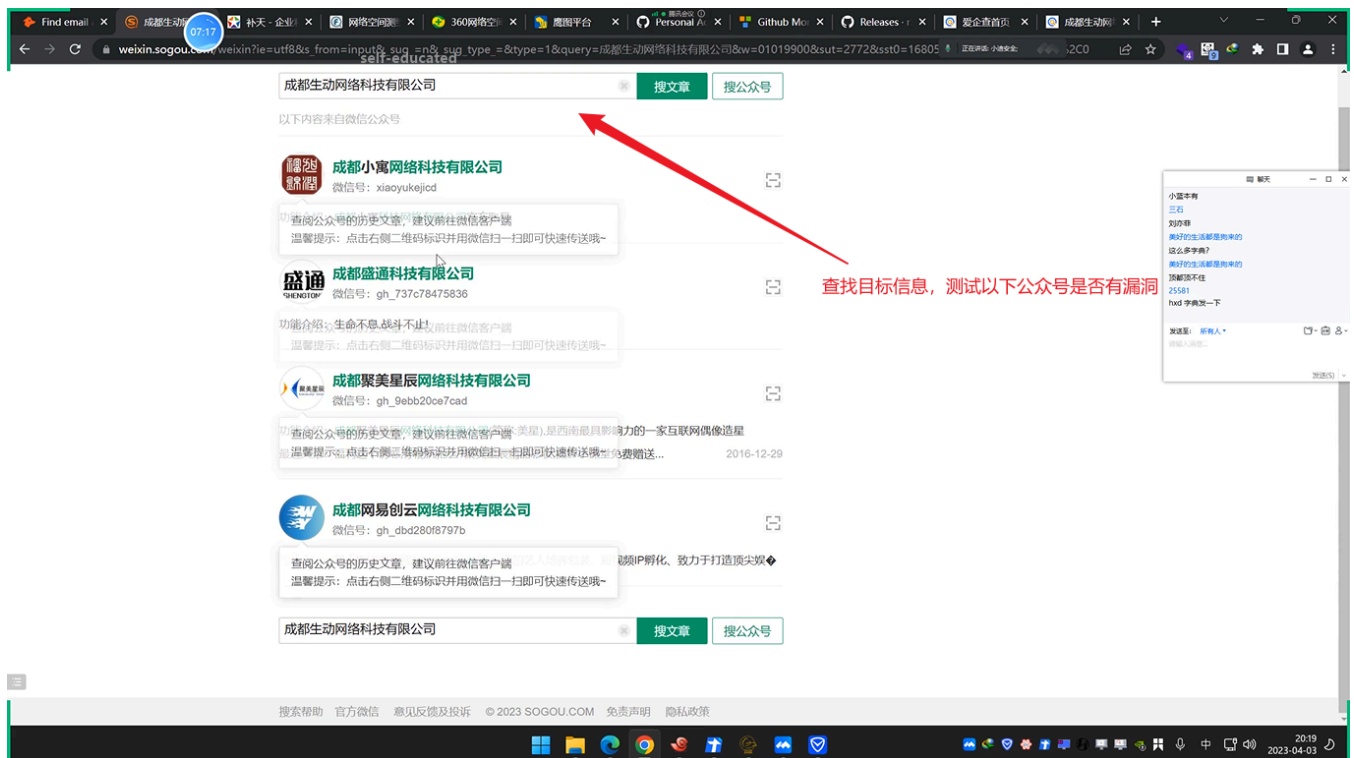
- 1 其他组件信息
- 2 fastjson、shiro、log4j、OA办公等

3.演示案例

3.1 微信公众号-获取&三方服务

- 1、获取微信公众号途径
- 2 <https://weixin.sogou.com/>
- 3 2、微信公众号有无第三方服务

(1) 直接使用上述网站搜索查找的目标:



- 1 微信公众号有无第三方服务，是否使用了非腾讯官方的接口等。

3.2 Github监控-开发&配置&源码

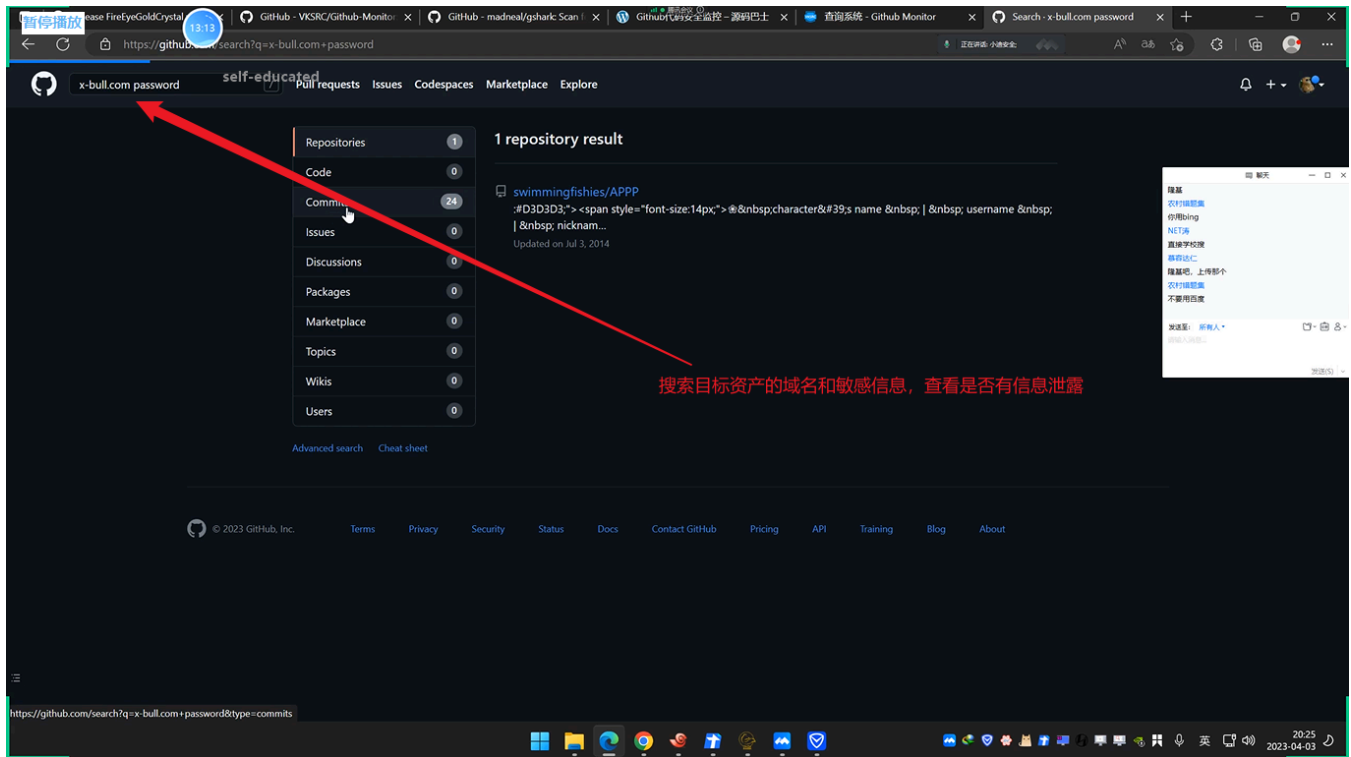
- 1 目标中开发人员或者托管公司上传的项目存在源码泄漏或配置信息（密码密钥等），人员数据库等敏感信息，找到多个脆弱点。
- 2 1、人员&域名&邮箱等筛选

```

3  eg: xxx.cn password in:file
4  https://gitee.com/
5  https://github.com/
6  https://www.huzhan.com/
7  GITHUB资源搜索:
8  in:name test           #仓库标题搜索含有关键字
9  in:descripton test     #仓库描述搜索含有关键字
10 in:readme test         #Readme文件搜索含有关键字
11 stars:>3000 test       #stars数量大于3000的搜索关键字
12 stars:1000..3000 test  #stars数量大于1000小于3000的搜索关键字 forks:>1000 test
    #forks数量大于1000的搜索关键字
13 forks:1000..3000 test  #forks数量大于1000小于3000的搜索关键字 size:>=5000 test
    #指定仓库大于5000k(5M)的搜索关键字 pushed:>2019-02-12 test    #发布时间大于2019-02-12的搜索
    关键字 created:>2019-02-12 test  #创建时间大于2019-02-12的搜索关键字 user:test
    #用户名搜索
14 license:apache-2.0 test #明确仓库的 LICENSE 搜索关键字 language:java test          #在
    java语言的代码中搜索关键字
15 user:test in:name test  #组合搜索,用户名test的标题含有test的
16 关键字配合谷歌搜索:
17 site:Github.com smtp
18 site:Github.com smtp @qq.com
19 site:Github.com smtp @126.com
20 site:Github.com smtp @163.com
21 site:Github.com smtp @sina.com.cn
22 site:Github.com smtp password
23 site:Github.com String password smtp
24
25 2、语法固定长期后续监控新泄露
26 -基于关键字监控
27 -基于项目规则监控
28 https://github.com/madneal/gshark
29 https://github.com/NHPT/FireEyeGoldCrystal
30 https://github.com/Explorer1092/Github-Monitor

```

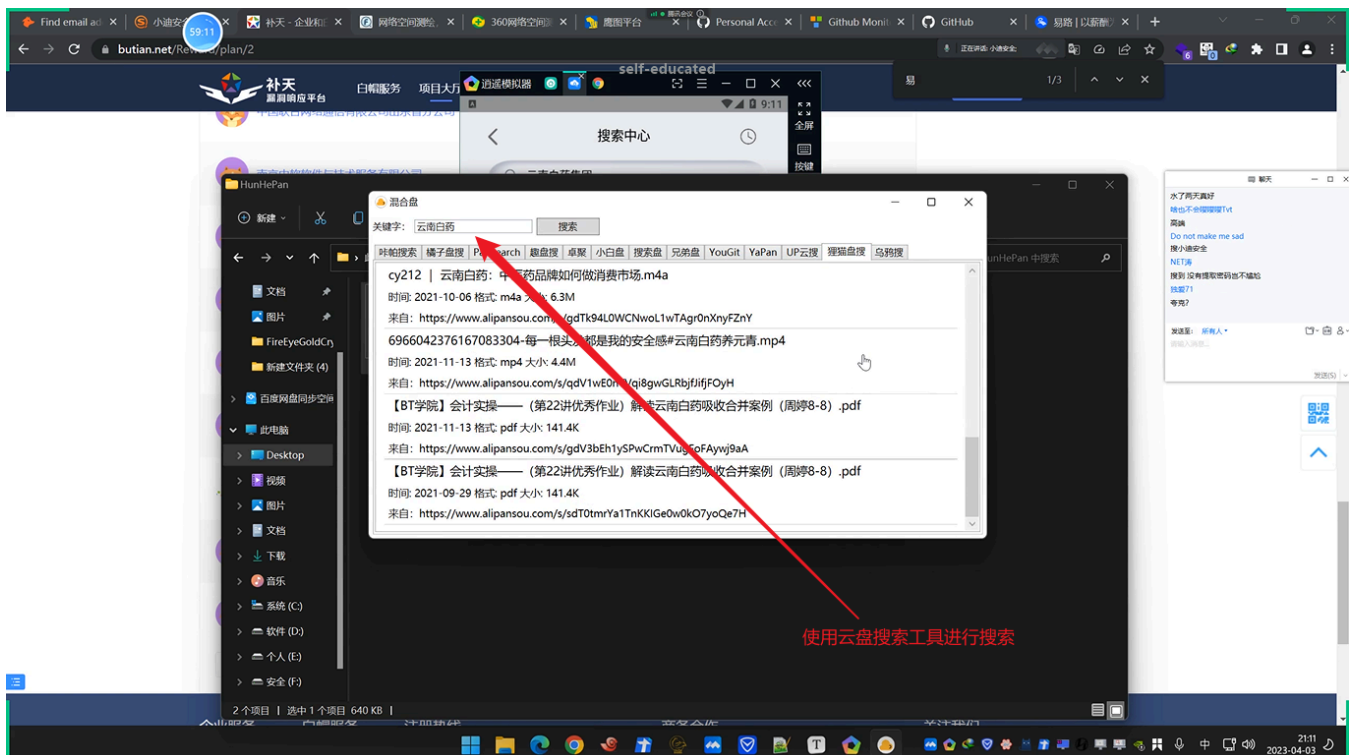
(1) 查看github是否存在测试目标信息泄露:



3.3 网盘资源搜索-全局文件机密

- 1 主要就是查看网盘中是否存有目标的敏感文件
- 2 如：企业招标，人员信息，业务产品，应用源码等

(1) 使用网盘搜索工具进行搜索：



3.4 网络空间进阶-证书&图标&邮箱



- 1 -证书资产
- 2 fofa quake hunter
- 3 -ICO资产
- 4 fofa quake hunter
- 5 -邮箱资产
- 6 <https://hunter.io/>

3.5 敏感目录文件-目录扫描&爬虫



- 1 -后续会详细讲到各类工具项目

3.6 实战案例四则-技术分享打击方位



- 1 案例1--招标平台二级跳
- 2 案例2--爱企查隐藏的惊喜
- 3 案例3--邮箱爆破到内网
- 4 案例4--不靠系统漏洞，从外网获取域控



- 1 详情参考课件内容。